

SlashAndGrab: The ConnectWise ScreenConnect Vulnerability Explained (CVE-2024-1709 / CVE-2024-1708)

Tactical Analysis Report — Analyst Use Only

ConnectWise ScreenConnect versions below 23.9.8 contain two critical vulnerabilities (CVE-2024-1709, CVSS 10.0, and CVE-2024-1708) allowing authentication bypass via a trivial path-traversal trick dubbed 'SlashAndGrab.' Huntress researchers built a proof-of-concept in under two hours and observed rapid in-the-wild exploitation within 48 hours, including ransomware drops, coin miners, and persistent remote access implants. Huntress responded by issuing 1,600+ incident reports to partners, publishing detection guidance, contributing Sigma rules to SigmaHQ, and deploying a proactive vaccine hotfix to vulnerable endpoints.

Threat Actor Profiles (1)

Unknown Threat Actors

Confidence: B2

MITRE ATT&CK Techniques (7)

ID	Name	Evidence / Use Note
T1190	—	One of the vulnerabilities was given a CVSS score of 10 out of 10, meaning it was the highest level of severity.
T1548	—	An Authentication Bypass is a flaw that allows attackers to go around security checks and access restricted areas without the proper permissions.
T1083	—	Path Traversal enables attackers to access files or directories on the server that they shouldn't be able to reach.
T1486	—	Attackers were using their new access to do all sorts of devious things, including dropping ransomware, cryptocurrency coin miners, and additional remote access to retain a presence on devices even after the ScreenConnect vulnerabilities were resolved.
T1496	—	Attackers were using their new access to do all sorts of devious things, including dropping ransomware, cryptocurrency coin miners, and additional remote access to retain a presence on devices even after the ScreenConnect vulnerabilities were resolved.
T1133	—	Attackers were using their new access to do all sorts of devious things, including dropping ransomware, cryptocurrency coin miners,

and additional remote access to retain a presence on devices even after the ScreenConnect vulnerabilities were resolved.

T1078	—	You can now create your own username and password and gain full access.
-------	---	---

Referenced CVEs (2)

CVE ID	Context
CVE-2024-1709	Authentication bypass vulnerability in ConnectWise ScreenConnect versions below 23.9.8, rated CVSS 10.0; exploited by appending a forward slash to the setupwizard.aspx URL to bypass authentication and create administrator credentials.
CVE-2024-1708	Path traversal vulnerability in ConnectWise ScreenConnect versions below 23.9.8, disclosed alongside CVE-2024-1709 in ConnectWise's February 19, 2024 advisory.

Kill Chain Phases Observed

exploitation	installation	command-and-control	actions-on-objectives
--------------	--------------	---------------------	-----------------------

Source Reliability Assessment

Admiralty code: **A2** — Reliable source, probably true.

Sectors Targeted

Information Technology	Managed Service Providers
All sectors using ConnectWise ScreenConnect on-premises	

Source Reference

<https://www.huntress.com/blog/slashandgrab-the-connectwise-screenconnect-vulnerability-explained-2>